

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Permission Review Meeting Worksheet

Run a quarterly permission review meeting that ends with decisions, not vibes. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

PERMISSION REVIEW MEETING WORKSHEET

For Governing AI Agents in Production Version 1.0 | © [Your Organization]

1. WORKSHEET OVERVIEW

This document is a **mandatory pre-approval checklist** for all AI agent deployments in production. It ensures compliance with **permissioning policies, cost controls, auditability, and incident response protocols**. Every field must be completed in full before approval.

Purpose: - Validate that AI agents operate within defined **governance boundaries**. - Document **access controls, usage limits, and escalation paths**. - Record **audit trails and cost-tracking mechanisms**. - Confirm **incident response readiness**.

Applies to: - New AI agent deployments. - Existing agents undergoing **permission or capability changes**. - Agents used in **high-risk workflows** (finance, legal, PII handling).

2. AGENT DETAILS

(Fill all fields with exact technical and operational specifics.)

Field	Value
Agent Name	[Exact internal/technical name]
Agent Type	[LLM API (e.g., Mistral, Llama2), Custom Model, Retrieval-Augmented, etc.]
Vendor/Provider	[Name of AI service provider]
Deployment Environment	[Cloud (AWS/GCP/Azure), On-Prem, Hybrid] + [Specific region/subnet]
Primary Use Case	[e.g., "Contract Review Assistant," "Customer Support Chatbot"]
Owner/Requestor	[Full name, role, email]
Stakeholders	[List all teams/roles with approval rights, e.g., "Legal," "Security"]
Deployment Date	[YYYY-MM-DD]
Expected Daily Queries	[Exact number or range (e.g., "100-500")]
Expected Cost (Monthly)	[\$XXX-\$XXX or "Unbounded (see Section 4)"]

3. PERMISSIONING & ACCESS CONTROLS

(Define granular access rules and enforcement mechanisms.)

3.1 User & Role-Based Access

Permission Level	Allowed Actions	Enforcement Method	Audit Trail Location
Admin	[e.g., "Full model access, permission edits, incident escalation"]	[IAM roles, RBAC, or custom API keys]	[SIEM log, CloudTrail, or internal DB]
Editor	[e.g., "Prompt tuning, fine-tuning, but no deployment rights"]	[Signed JWT tokens with scope restrictions]	[Same as above]
Viewer	[e.g., "Read-only access to agent outputs"]	[Temporary tokens with 1-hour expiry]	[Same as above]
End User	[e.g., "Limited to [specific workflows], no admin access"]	[OAuth 2.0 with claims-based auth]	[User activity logs in [system]]

Exception Handling: - **Temporary overrides** (if any): [Describe process, e.g., "Only via Jira ticket #AI-REQ-XXX approved by Security."] - **Emergency access:** [Define criteria, e.g., "Only for P0 incidents: requires dual approval."]

3.2 Data & Output Controls

Control	Implementation	Verification Method
Input Validation	[e.g., "Block PII via regex, reject queries >1024 tokens"]	[Automated pre-flight checks in API gateway]
Output Sanitization	[e.g., "Strip sensitive patterns, flag hallucinations with [tool]"]	[Post-processing with [specific NLP filter]]
Audit Logging	[e.g., "Log all prompts/responses to [S3 bucket] with immutable signatures"]	[Sample logs reviewed by Security monthly]
Third-Party Data Access	[e.g., "Only via approved API keys with IP whitelisting"]	[Verify via [security tool] weekly]

4. COST & RESOURCE MANAGEMENT

(Prevent runaway spending and resource exhaustion.)

Metric	Threshold	Alert Mechanism	Automation Rule	Escalation Path
Token Usage (Daily)	[e.g., "Alert at 1.2x baseline"]	[Slack alert + PagerDuty for >1.5x]	[Auto-scale-down if >2x for 30 mins]	[IT + Finance approval required]
API Call Rate	[e.g., "Block if >500 RPS"]	[Cloud WAF rate-limiting]	[Kill switch after 3 failed retries]	[SRE team on-call]
Memory/CPU Usage	[e.g., "Kill if >80% CPU for 5 mins"]	[Kubernetes HPA + Prometheus alerts]	[Auto-terminate pod]	[DevOps team]

Metric	Threshold	Alert Mechanism	Automation Rule	Escalation Path
Vendor API Cost	[e.g., "Cap at \$10K/month"]	[AWS Budgets + custom Lambda guardrail]	[Pause agent if exceeded]	[Finance + Legal review]

Cost Tracking: - Tagging: [All agent-related spend tagged with [project-name]-ai for granular billing.] - **Review Frequency:** [Monthly review by [role], quarterly by [role].]

5. INCIDENT RESPONSE & COMPLIANCE

(Define how breaches, failures, or policy violations are handled.)

5.1 Incident Classification

Severity	Criteria	Response Team	Time-to-Resolve
P0	[e.g., "Data breach, hallucination causing legal risk"]	[Security + Legal + Compliance]	<1 hour
P1	[e.g., "Cost overrun >\$5K, model poisoning attempt"]	[IT + Finance]	<4 hours
P2	[e.g., "Performance degradation, minor compliance gap"]	[DevOps + Owner]	<24 hours

5.2 Compliance Checks

Regulation	Requirement	Evidence of Compliance
GDPR	[e.g., "Right to erasure for user data"]	[Automated purge scripts + audit logs]
HIPAA	[e.g., "No PHI in prompts/outputs"]	[DLP scans + signed attestation from Owner]
Internal Policy	[e.g., "No political/sensitive topics"]	[Prompt filtering rules + monthly compliance report]

5.3 Post-Incident Review

- **Root Cause Analysis (RCA):** [Template: [link to internal doc]] required for all P0/P1 incidents.
- **Retrospective Meeting:** [Scheduled within 7 days of incident; attended by [roles].]
- **Documentation:** [Update [incident wiki] with lessons learned.]

6. AUDIT TRAIL & MONITORING

(Ensure traceability of all agent interactions.)

Component	Audit Details Logged	Retention Policy	Access Restrictions
Prompts	[Raw input, sanitized output, timestamp, user ID, agent version]	[7 years (GDPR) or [custom period]]	[Read-only for Security, full access for Owner]
System Events	[Deployment changes, permission edits, cost alerts]	[30 days in cold storage]	[Audit-only for Compliance]
User Activity	[Query history, response timestamps, agent decisions]	[180 days, then redacted]	[Limited to [roles]]

Tools Used: - [Primary logging system: [e.g., Datadog, Splunk, ELK]] - [Secondary backup: [e.g., S3 immutable logs]]

7. QUALITY SELF-CHECK

(The following 5 items must be visibly passed before approval.)

- [x] **1. Permissioning** All roles (Admin/Editor/Viewer/End User) have **explicit, non-overlapping permissions** with enforcement mechanisms documented.
- [x] **2. Cost Controls** At least **two independent safeguards** (e.g., rate limits + budget caps) are in place, with **automated escalation** for breaches.
- [x] **3. Audit Trail** All **critical actions** (prompts, outputs, permission changes) are logged with **immutable timestamps** and **access-controlled storage**.
- [x] **4. Incident Response** A **classified incident hierarchy** (P0-P2) exists with **assigned teams and SLAs**, and **post-mortem requirements** are defined.
- [x] **5. Compliance Alignment** The agent's **data handling and output restrictions** align with **all applicable regulations** (e.g., GDPR, HIPAA), with **verifiable enforcement**.

8. APPROVALS

(All signatories must initial and date.)

Role	Name	Signature	Date
Owner/Requestor	[Full Name]		
Security Lead	[Full Name]		
Compliance Officer	[Full Name]		
Finance Approver	[Full Name]		
IT/DevOps	[Full Name]		

Final Note: "By signing, all parties confirm that this worksheet fully captures the risks, controls, and governance requirements for [Agent Name]. Failure to adhere to these terms may result in immediate revocation of permissions."

End of Worksheet For internal use only. Unauthorized duplication prohibited.

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com